



Enterprise ISO/IEC 27001:2022 & NIST CSF v1.1 Audit Working Papers

Standard di Riferimento: ISO 19011:2018, ISO/IEC 27001:2022 & NIST CSF v1.1

Organizzazione: Aetheris Therapeutics S.p.A.

Rif. Documento: AUD-TR-2026-02

Versione: 1.0

Stato: Approvato

Classificazione: Riservato / Per Uso d'Audit

Data di Efficacia: Agosto 2026

1. Informazioni Generali e Finalità

Il presente **Audit Trail (Registro dell'Audit)** traccia in modo sistematico tutte le attività svolte durante la fase di *Fieldwork* e verifica sul campo presso **Aetheris Therapeutics S.p.A.**

Documenta le interviste condotte, i campionamenti effettuati, l'analisi dei log, la revisione delle configurazioni di rete e la correlazione diretta tra le evidenze obiettivo raccolte e i Rilievi finali (Non-Conformità NC e Opportunità di Miglioramento OFI).

Audit Team & Periodo

- **Lead Auditor:** Emanuele Tarchi (ISO 27001 Lead Auditor Trainee / GRC Specialist)
- **Supporto & Escort Tecnico:** IT Director & Senior Systems Administrator
- **Fasi Operative:** Preparazione (1 sett.), Fieldwork e Campionamento (2 sett.), Reporting (1 sett.)

2. Registro degli Stakeholder Intervistati

Ruolo / Funzione	Dipartimento	Modalità di Verifica	Data / Sessione
IT Director & Systems Administrator	IT Operations	Intervista tecnica & Walkthrough architetturale	Giorno 1
Senior Systems Administrator	IT Infrastructure	Review configurazioni Active Directory, Palo Alto & Azure	Giorno 1
Cybersecurity Analyst	Security Operations	Intervista su Monitoring, SIEM, Incident Response e EDR	Giorno 2
Legal, Compliance & HR Manager	HR & Governance	Intervista funzionale su GDPR, Screening, NDA e Fornitori	Giorno 3
R&D Lab Manager	Ricerca & Sviluppo	Walkthrough fisico e logico nei laboratori R&D	Giorno 3

(I dettagli anagrafici dei singoli dipendenti sono omessi nel rispetto della privacy e del GDPR).

3. Evidenze Obiettivo Raccolte (Audit Working Papers)

3.1 Interviste e Dichiarazioni Significative (Fieldwork)

Le trascrizioni complete delle interviste sono archiviate in `evidences/Interview_Transcripts.md`. Di seguito i passaggi rilevanti emersi durante i colloqui:

"Gestiamo l'inventario dei laptop e dei server tramite un foglio Excel aggiornato manualmente. Non disponiamo di un sistema CMDB o di una discovery automatica..." **(IT Manager)**

"Non esiste una procedura formale e scritta per la gestione degli incidenti di sicurezza (Incident Response Plan); quando si verifica un'anomalia interveniamo in modo reattivo..." **(Cybersecurity Analyst)**

"Manca un Registro dei Trattamenti dei dati (Art. 30 GDPR) formale e aggiornato per la parte dei dati sanitari e clinici dei pazienti..." **(Legal & HR Manager)**

3.2 Esame Documentale

Documento Analizzato	Fonte / Origine	Valutazione dell'Auditor	Esito
Policy di Sicurezza IT Generica	IT Department	Documento obsoleto, privo di approvazione della Direzione	NC Minor
Diagrammi di Architettura di Rete	Network Team	Aggiornati; evidenziano segmentazione VLAN corretta nei laboratori	PASS
Configurazioni Firewall Palo Alto	Network Team	Regole di egress/ingress ben definite e documentate	PASS
Registro dei Trattamenti GDPR (Art. 30)	Legal/Compliance	Assente; nessuna mappatura formale dei dati PII/GDPR	NC Major
Piano di Risposta agli Incidenti (IRP)	Security Operations	Assente; nessuna matrice di escalation o procedura scritta	NC Major
Contratti con Fornitori SaaS / Cloud	Procurement/ Legal	Mancano clausole obbligatorie di audit cyber e breach notification	NC Minor

3.3 Verifiche Tecniche e Campionamenti sul Campo

Ambito di Verifica	Descrizione della Campionatura / Check Tecnico	Rilievo Associato
Asset Management	Campionamento su 15 laptop: inventario gestito solo su Excel, senza agent automatizzato	ID.AM-1 / A.5.9 (NC)
Gestione Accessi Remoti	Verifica gateway VPN: autenticazione attiva solo tramite username e password, assenza MFA	PR.AC-3 / A.8.5 (NC)
Account Amministrativi	Campionamento Active Directory: credenziali Domain Admin condivise tra più operatori IT senza PAM	PR.AC-4 / A.8.2 (NC)
Monitoring & Detection	Verifica infrastruttura: assenza di SIEM per la correlazione centralizzata dei log di sistema	DE.AE-3 / A.8.15 (NC)
Protezione Endpoint	Verifica su 10 workstation R&D: Antivirus tradizionale presente, ma assenza di soluzione EDR	DE.CM-4 / A.8.7 (OFI)
Data Loss Prevention	Verifica flussi dati: assenza di controlli DLP sulle email e sulle uscite USB	PR.DS-4 / A.8.12 (NC)

4. Verifiche Tecniche Effettuate (Walkthrough)

4.1 Check-list Infrastrutturale

- **Segmentazione di Rete:** Confermata la separazione della rete R&D dai sistemi amministrativi generali tramite Next-Gen Firewall Palo Alto.
- **Active Directory & Identity:** Verificati i criteri di complessità delle password (minimo 12 caratteri), ma riscontrata l'assenza di rotazione periodica per le utenze privileged.
- **Backup & Disaster Recovery:** Verificata l'esecuzione dei backup notturni su Azure Storage con immutabilità attiva; condotto test di ripristino con esito positivo.

4.2 Risultati del Controllo ISO/IEC 27001:2022 (Annex A)

La valutazione completa dei 93 controlli è documentata in docs/Aetheris_Therapeutics_ISO27001_Annex_A_SoA_Evaluated.pdf.

* **Controlli Conformi (PASS):** 4

* **Controlli Non Conformi / Parziali (NC/OFI):** 89

5. Matrice di Correlazione: Evidenza → Rilievo ISO/NIST

Evidenza Obiettivo Raccolta	Rilievo Assegnato	Riferimento NIST CSF	Riferimento ISO 27001:2022
Gestione manuale e incompleta degli asset IT	NC Minor	ID.AM-1 / ID.AM-2	Clausola 5.9 / Annex A.5.9
Connessione VPN accessibile senza Multi-Factor Authentication	NC Major	PR.AC-3	Annex A.5.15 / A.8.5
Credenziali amministrative condivise e assenza di PAM	NC Major	PR.AC-4	Annex A.5.18 / A.8.2
Assenza di SIEM e di monitoraggio centralizzato h24	NC Major	DE.AE-3 / DE.CM-1	Annex A.8.15 / A.8.16
Mancanza di un Incident Response Plan formalizzato	NC Major	RS.RP-1	Clausola 5.24 / Annex A. 5.26
Assenza del Registro dei Trattamenti GDPR (Art. 30)	NC Major	ID.GV-3	Clausola 4.2 / Annex A. 5.34

6. Struttura dell'Archivio Evidenze (evidences/)

Tutti i file sorgente, le note e le schermate a supporto dell'audit sono organizzati nella cartella dedicata del repository:

```
evidences/  
├─ Interview_Transcripts.md    <-- Trascrizione integrale dei colloqui  
├─ Sampling_Log.md            <-- Verifiche a campione su utenze e dispositivi  
└─ Config_Review_Notes.md     <-- Note tecniche su Palo Alto, Azure AD e VPN
```

7. Conclusioni dell'Audit Trail

L'Audit Trail attesta che:

1. Le evidenze raccolte durante le verifiche sono obiettive, tracciabili e documentate.
2. Le valutazioni di Non-Conformità su ISO 27001 e NIST CSF sono supportate da riscontri di fatto.

3. I dati raccolti forniscono una base solida e inconfutabile per la redazione del **Registro dei Rilievi** (`NC_OFI_Matrix.md`), del **Registro Rischi ISO 27005** (`risk/Risk_Register.md`) e della **Strategic Roadmap per la Direzione**.

8. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	Agosto 2026